

Comprehensive Patch Notes

Complete record of every feature added to the platform

RELEASE	Release JDMv4 · build e725eb4
DATE	29 September 2026
DOCUMENT	SW-PN-2026-09-29 · Rev. 1.0
BASELINE	Baseline commit 6daf284 (Adjustments in Session Expiry)
CLASSIFICATION	Internal - Product, Engineering, QA, Support
PLATFORM	React 18 + Vite 8 client Node 18 + Express 4 + Mongoose 8 API

- 1 Release Overview
- 2 Member Experience
- 3 Web3 and Blockchain Layer
- 4 Administrator Console
- 5 Backend and API
- 6 Security Programme
- 7 Progressive Web App and Mobile
- 8 Testing and Verification
- 9 Known Gaps and Manual Actions
- 10 Appendix - Feature to Source Map

1. Release Overview

This document records every feature, security control, capability and platform improvement delivered to SuppliWise up to build e725eb4. It is organised by module rather than by commit, so a reader interested in one subsystem can read that section end to end without wading through unrelated work.

The system in scope is the full SuppliWise platform: the member-facing web and mobile application, the administrator control panel, the Express/MongoDB API, the embedded blockchain (Web3) layer, and the operational tooling that supports them. Where a feature exists in documentation but has since been superseded, this document records the shipped behaviour rather than the original note.

VERIFICATION CAVEAT CARRIED FORWARD FROM THE BUILD LOG

The desktop browser was unavailable during part of this release, so a number of visual changes are recorded as "built and compiled" rather than "seen in a running browser". Every claim in this document rests on static analysis, automated tests and production builds. Section 9.3 lists the specific items that still warrant a manual visual pass.

1.1 Scope and provenance

FIELD	VALUE
Product	SuppliWise
Release	Release JDMv4 (build e725eb4)
Baseline	Baseline commit 6daf284 (Adjustments in Session Expiry)
Documentation date	29 September 2026
Document ID / revision	SW-PN-2026-09-29 / Rev. 1.0
Classification	Internal - Product, Engineering, QA, Support
Client stack	React 18, Vite 8, React Router 7, jsPDF, vite-plugin-pwa, Capacitor 8
Server stack	Node 18, Express 4, Mongoose 8, helmet, express-rate-limit, jsonwebtoken, hash-wasm (argon2id), nodemailer, speakeasy, qrcode
Source layout	my-react-app/ (client, port 5173) server/ (API, port 5000) docs/ (manuals)

1.2 What shipped in this release

MODULE	SUMMARY OF ADDITIONS	SCALE
Member application	Four-step health assessment, AI recommendation plan, daily intake tracking with a colour-coded calendar, insights analytics, tiered history, PDF report export, profile customisation, plan catalogue and checkout, account security centre, notification inbox and human support threads, AI chat assistant.	18 feature areas
Account security	Two-factor authentication with a method picker, single-use recovery codes, recovery email, step-up confirmation, signed-in device management, and a structured security activity feed.	7 controls
Web3 / blockchain	A 20-feature permissioned blockchain layer: supply chain provenance, verifiable certifications, escrow marketplace, decentralised identity, user-owned health ledger, data-sovereignty consent, encrypted storage, WELL rewards, achievement NFTs, staking, loyalty, DAO governance, a community knowledge base, juror-based dispute resolution, public share links, verifiable AI proofs, clinical trial consent, oracle feeds and tokenised expert bookings.	20 features, 22 models
Administrator console	An eight-tab control panel with a 45-probe live security monitor, AI provider health probing, user and administrator management, two subscription review queues, a support inbox, assessment management with a priority override, and a self-service administrator profile.	8 tabs, 43 endpoints
API and backend	17 route modules, 17 Mongoose models, 42 server utilities, layered rate limiting, a global request flood guard, and four operational scripts.	17 routes, 42 utils
Security programme	A 30-finding security audit across six phases, with 23 remediations shipped in code and 7 items documented as accepted.	30 findings
Mobile and PWA	An installable Progressive Web App with app shortcuts and silent auto-update, plus Capacitor Android packaging for a sideloadable debug APK.	PWA + APK
Verification	44 server test files, 9 client test files, and six live/adversarial suites covering real HTTP flows, session lifecycles, Web3 features and attack probes.	600+ assertions

1.3 How to read this document

- **NEW** marks a capability that did not exist before this release.
- **EXPANDED** marks an existing capability that gained meaningful new behaviour.
- **HARDENED** marks a change whose purpose is defence, correctness or reliability rather than new user-facing capability.
- **FIXED** marks a defect that was corrected during the release.
- Every module lists the source files that implement it, so a reader can move directly from the note to the code.
- Section 9 records gaps that remain open. They are stated plainly rather than omitted, because a patch note that only lists successes is not a useful patch note.

2. Member Experience

Everything a SuppliWise member can reach: the public pages, the account and sign-in flows, the assessment, the plan, the daily tracking loop, the analytics, the history, the profile, the paid tiers and the support channels.

2.1 Application shell, routing and reliability

Global error boundary (NEW)

Any uncaught render error now produces a recoverable screen instead of a white page. A React error boundary catches the failure and offers **Refresh Page** and **Go to Home**. Before surfacing the error page it self-heals a stale lazy-chunk hash with a single deduplicated reload, which resolves the most common cause of the failure without the member seeing anything at all.

```
my-react-app/src/App.jsx
my-react-app/src/Utils/chunkReload.js
my-react-app/src/Utils/chunkReload.test.js
```

Route-level code splitting (EXPANDED)

Every page except the landing page is lazily loaded behind a single Suspense boundary, which reduced the initial bundle from roughly 1,027 KB to about 190 KB plus per-page chunks. jsPDF and jsPDF-AutoTable are pre-bundled through the Vite dependency optimiser so the first Export click never triggers a mid-session re-optimise - the previous behaviour was a 504 gateway timeout on the user's first report download.

```
my-react-app/src/App.jsx
my-react-app/vite.config.js
```

Session bootstrap gate (NEW)

On a brand-new tab the application briefly waits for a cross-tab session hand-off before any route guard can bounce the member to the sign-in page. First-time visitors with no known accounts skip the wait entirely, so a genuinely new user never sees a spinner.

```
my-react-app/src/App.jsx
my-react-app/src/api.js
```

Password field hardening (HARDENED)

A document-level capture listener makes copy, cut, paste, context menu, drag-start and text selection no-ops inside any password input. A credential can no longer be lifted through the clipboard or read over a shoulder while selected.

```
my-react-app/src/App.jsx
```

Network resilience across phones, tablets and LAN (HARDENED)

The API base URL is now derived from the page host, so a phone loading the client from 192.168.x.x:5173 reaches 192.168.x.x:5000 without any configuration; an explicit environment override remains available. Every request carries a hard timeout - 30 seconds by default, 150 for AI recommendations, 45 for chat and

supplement detail, 60 for saving results. Safe GET requests retry once on a connection failure, and failures surface as plain English rather than a raw network error.

`my-react-app/src/api.js`

No more false logouts (FIXED)

Member sessions no longer end because of inactivity, and a session only ends when the API explicitly says so with a session code. When it does, the client fingerprints the dead token - never storing the token itself - broadcasts the event to sibling tabs, clears only the affected tab, and drops a one-shot explanatory notice onto the sign-in form. This removed a fatal redirect loop between the sign-in page and the dashboard.

`my-react-app/src/api.js`

`my-react-app/src/Pages/LogIn.jsx`

2.2 Public and guest surfaces

Landing page with a full how-it-works story (NEW)

The guest landing page opens with a hero, three statistic chips (4-step assessment, AI-powered analysis, 100% personalised) and calls to action into the assessment and the plan catalogue. Below it sits a three-card narrative - health assessment, AI analysis, track progress - with a permanent medical disclaimer, a plan teaser drawn from the same catalogue module the pricing page uses, and a footer with permanent links.

`my-react-app/src/Pages/HomePage.jsx`

`my-react-app/src/subscription/catalogue.js`

Public product verification by QR code (NEW)

A consumer holding no account can type or scan the SW-XXXXXXX code printed on a bottle and receive a tamper-evident verdict. The server recomputes every anchored transaction's block hash on the spot rather than trusting a stored claim, so an edited record fails. The page presents a verdict badge (Authenticated and Verified, Proof Incomplete, or Not Verified), product identity, four statistic tiles, a seven-step journey timeline from raw sourcing through to delivery with a copyable block reference per step, and a certifications table covering lab report, organic, non-GMO, third-party and GMP.

`my-react-app/src/Pages/VerifyPage.jsx`

`my-react-app/src/api/web3.js`

Public read-only health profile sharing (NEW)

A member can generate a clinician-facing profile link; the recipient needs no account. The token itself is the capability and is gated server-side by a time limit and revocability. The page shows identity and demographics, validity window, view count, four summary statistics, the latest assessment context, and - when anchored - the integrity anchor with its block number and ledger digest, alongside a not-a-diagnosis disclaimer.

`my-react-app/src/Pages/SharePage.jsx`

`my-react-app/src/api/web3.js`

2.3 Authentication and account access

Create account with strict field validation (EXPANDED)

Registration collects first name, last name, date of birth, gender, email, password, confirmation and a server-issued arithmetic CAPTCHA. Name fields strip anything that cannot appear in a name as it is typed or pasted, so digits, symbols and emoji are simply impossible to enter. Date of birth validation rejects impossible calendar dates and ages outside 1 to 120 using a local date construction so no timezone can shift the day. Email validation rejects common typo top-level domains with a corrective suggestion rather than a generic error.

```
my-react-app/src/Pages/SignIn.jsx
my-react-app/src/Utils/nameValidation.js
my-react-app/src/Utils/nameValidation.test.js
```

Adaptive second factor at sign-in (NEW)

Sign-in is a two-step flow whose second step adapts to the account: an emailed six-digit code by default, an authenticator-app code, or a single-use recovery code in A1B2C-D3E4F form. The dialog shows the target address, a live ten-minute countdown that turns red and pulses under sixty seconds and disables input at zero, a resend control with a thirty-second cooldown, and a lost-your-phone toggle that appears only for the authenticator method.

A "Save my login on this browser" checkbox is on by default. It stores a session-bound saved-login marker - never the password and never an access token - so that account switching later never asks for the password again.

```
my-react-app/src/Pages/LogIn.jsx
my-react-app/src/api.js
my-react-app/src/auth/authState.js
```

Password recovery rebuilt as two real pages (NEW)

Password recovery moved out of a modal into two dedicated routes, because the flow ends in a link clicked from an email - usually in a new tab, sometimes hours later.

- **Forgot password** - address pre-filled from sign-in, a sixty-second resend cooldown, and a confirmation that states the link works once and expires in thirty minutes. The same confirmation is shown whether or not the account exists, which prevents account enumeration.
- **Reset password** - five distinct screens: checking the link, a missing-link state, an expired-link state (deliberately worded differently from the missing one), a throttled too-many-attempts state, the form, and the success confirmation.
- The form carries a five-segment strength meter and a live six-item checklist fetched from the server: 10 to 128 characters, an uppercase letter, a lowercase letter, a number, a symbol, and not a common or guessable password.
- Redeeming a reset signs out every device, and that fact is reported on screen rather than surfacing as an unexplained redirect.

```
my-react-app/src/Pages/ForgotPassword.jsx
my-react-app/src/Pages/ResetPassword.jsx
my-react-app/src/Pages/PasswordReset.css
my-react-app/src/Utils/passwordPolicy.js
my-react-app/src/Utils/passwordPolicy.test.js
```

Multi-account, per-tab sessions and the account switcher (NEW)

Multiple accounts can be signed in at the same time, one per browser tab. Credentials live in per-tab session storage, only non-sensitive metadata is shared in local storage, and a BroadcastChannel hands live sessions between tabs. The account menu exposes an Accounts view listing every account signed in on this browser, marking the current one, with Switch and a two-step sign-out action, plus an option to add another account.

A switch is silent when a saved login or a handover from another open tab makes it possible, and otherwise falls back to the sign-in page with the address prefilled. Signing out revokes only that account's session everywhere, and lands on the member sign-in form rather than the administrator panel.

```
my-react-app/src/Components/AccountSwitcher/AccountSwitcher.jsx
my-react-app/src/api.js
my-react-app/src/auth/authState.js
```

One-shot sign-out explanations (NEW)

When a session ends because of a newer sign-in, a sign-out elsewhere, or a revoked token, the sign-in page shows a single explanation - including a distinct message for inactivity-based sign-out - so a member whose password works fine never concludes that the application is broken.

2.4 Health assessment

Four-step questionnaire (EXPANDED)

The core intake form is four steps with a progress bar and an auto-saved draft held in session storage. Read-only history views deliberately never persist a draft, so viewing an old record can never contaminate a new one.

STEP	CAPTURES
1 - Basic information	Age with live computed value, gender, weight in kg or lb with automatic conversion, height in cm or ft+in with automatic conversion, and activity level. Activity level is hidden for children under 13.
2 - Diet and health goals	Ten diet types, each with an explanatory tooltip, plus health goals.
3 - Current symptoms	General symptoms and condition-specific symptom groups, each with Mild, Moderate or Severe severity, plus stress level, sleep quality and water intake.
4 - Medical and lifestyle	Conditions, medications, allergies, pregnancy and breastfeeding status, lifestyle habits, sun exposure, protein intake, current supplements, recent blood test and results, and recreational drug types.

Every option that needs explaining - diet types, activity levels, health goals and the twenty medical conditions - carries an inline tooltip. Spam-text detection rejects a field that is five repeated characters or pure punctuation.

```
my-react-app/src/Pages/AssessmentPage.jsx
my-react-app/src/Pages/AssessmentPage.css
```

Read-only history view (NEW)

History to "View Assessment" opens the identical four-step form with the member's answers reconstructed. Every input, select and textarea is disabled and marked read-only, and every in-body button is disabled except

the diet and condition tooltips, which remain usable. Leaving the view discards the draft, so a half-typed form can never follow the member into their next assessment.

```
my-react-app/src/Pages/AssessmentPage.jsx  
my-react-app/src/Components/ReadOnlyAssessment/ReadOnlyAssessment.jsx
```

Priority review gate (NEW)

While an assessment is flagged for priority review, starting a new assessment is paused. A modal on the dashboard explains how many reviews are open and links to History, the New Assessment card is badged as paused, a red banner shows the flag date and reasons, and the assessment page itself refuses the submission. The gate is a paid entitlement and is re-checked live, so a premium upgrade lifts it immediately and a downgrade re-applies it. Read-only history views are never blocked.

```
my-react-app/src/Pages/DashboardPage.jsx  
my-react-app/src/Pages/AssessmentPage.jsx  
my-react-app/src/api.js
```

Automatic lift and strict re-flag (NEW)

Completing 100% of a flagged assessment's daily supplements resolves the review automatically and unlocks new assessments. Undoing that completion re-instates the flag. The restriction is therefore a real state machine rather than a cosmetic badge.

```
my-react-app/src/Pages/DashboardPage.jsx  
my-react-app/src/Pages/TrackIntakePage.jsx
```

2.5 Results and the recommendation plan

Simplified and Detailed detail mode (NEW)

A two-state toggle in the results header lets the member choose how technical the plan reads, and the choice is remembered per browser. Simplified shows plain-language summary, reason and evidence, larger type and an expandable food-source list. Detailed shows the clinical text with jargon, interactions, side effects, citations, duration and the evidence information control.

```
my-react-app/src/Pages/ResultsPage.jsx
```

Recommendation cards (NEW)

Each card carries a priority pill, a large supplement-specific glyph, an animated match confidence bar that counts up and is colour-scaled, a "recommended for" line, a condition context line, a duration field, and an interactions warning where one exists. Expanding a card reveals evidence and references, food sources, and side effects with safe limits. Results open with six cards and a "Show more" control, sorted by priority and then by confidence score.

```
my-react-app/src/Pages/ResultsPage.jsx
```

On-demand AI supplement detail (NEW)

Tapping a supplement name opens an assessment-aware detail sheet covering an overview, key benefits and use cases, how to take it, considerations and safety, and availability. The request carries the member's own context - age, gender, symptoms, goals, conditions, allergies, lifestyle, diet, pregnancy status and the reason for the recommendation - so the answer is specific rather than generic.

Results are cached for 30 days both in local storage and in memory, scoped per user and per assessment, so accounts never share detail blobs and a new assessment always re-fetches.

```
my-react-app/src/Pages/ResultsPage.jsx  
my-react-app/src/api.js
```

Food source expansion (NEW)

Generic food categories are expanded into concrete examples as chips - "fatty fish" becomes "fatty fish (salmon, tuna, sardines, mackerel)" - across nineteen categories, with parenthesis-aware splitting so commas inside examples are not treated as separators.

```
my-react-app/src/Pages/ResultsPage.jsx
```

Evidence and references transparency modal (NEW)

An information control beside the evidence label opens a panel stating the exact methodology used to gather citations: peer-reviewed research from the last two years first; failing that, clinically relevant evidence from the last five years; before citing an older landmark study, a recent systematic review, meta-analysis or guideline that builds on it; and otherwise landmark studies or guidelines still widely accepted and uncontradicted, which must be clearly labelled as such.

The panel also names the quality hierarchy - systematic reviews and meta-analyses first, then clinical guidelines, then randomised controlled trials, then observational studies - states the citation format including PubMed identifiers, and carries an AI-assisted and consult-a-professional disclaimer. A matching footer paragraph repeats the policy at the bottom of the results page.

```
my-react-app/src/Pages/ResultsPage.jsx
```

Plan sections and clinical safety surfaces (EXPANDED)

The results page presents a header strip (plan items, health goals, daily moments, care check), a personalised summary, and then supplement recommendations, a daily schedule and recovery plan with time-of-day slots and numbered recovery phases with expected changes, lifestyle recommendations, meal recommendations, supplements to avoid, important warnings, and a seeking-support resource block that appears only when recreational drug use is reported.

Two safety surfaces were added alongside it. A "Medical consultation recommended" alert appears above the plan when the AI asks for a referral, and a permanent wellness-guidance banner is always present. A separate warning card names any free-text answers that were rejected during analysis and shows the offending text, so a member knows which inputs are missing from the plan and can retake the assessment.

AI-generated links render only when they are HTTP(S) or application-relative; a javascript-scheme value renders the card unlinked rather than executing.

```
my-react-app/src/Pages/ResultsPage.jsx  
my-react-app/src/utils/safeUrl.js
```

PDF report export (NEW, Deluxe and above)

Export produces a formatted wellness report with an educational-purpose notice, four summary tiles, a clinical summary, a medical-consultation card when relevant, and a patient snapshot table covering identity, demographics, computed BMI with its band, activity and diet, sleep and hydration, goals, symptoms, conditions and allergies, followed by the supplement plan and remaining sections.

The client gates on the export entitlement and the server re-verifies the same entitlement before the browser renders anything. The PDF library is dynamically imported on click, so no route that merely offers the button pays its cost.

```
my-react-app/src/Utils/exportPDF.js
my-react-app/src/Utils/wellnessReport.js
my-react-app/src/Pages/ResultsPage.jsx
my-react-app/src/Pages/HistoryPage.jsx
```

2.6 My recommendations

Recommendation library with add-to-plan (NEW)

A dedicated page loads the latest assessment's recommendations in parallel with the current plan, so the "added to plan" state is correct on first paint rather than flashing. Filter tabs separate all, high, medium and low priority. Each card shows name, priority, dosage, timing, a "why this supplement" block and key benefits, with a toggle that adds the supplement - name, dosage, timing and priority - to the plan or removes it again.

Sorting places not-yet-added items first, then by priority, then by descending confidence. A persistent consult-a-professional warning sits above the list and a purpose-built empty state points new members at the assessment.

```
my-react-app/src/Pages/RecommendationsPage.jsx
my-react-app/src/api.js
```

2.7 Dashboard and daily tracking

Member dashboard (NEW)

A personalised greeting, four large action cards, today's supplement list with a priority colour legend, a wellness score out of 100 with a horizontal bar and a hover explainer that breaks it into health baseline (0 to 30), adherence (0 to 50) and streak bonus (0 to 20), and a quick-stat grid covering streak in days, adherence rate and today's progress as a taken-over-total count with a completion check.

Supplements are sorted untaken first, then by time of day, then by priority. Marking as taken is optimistic with server-side rollback on failure, and a taken row becomes a read-only pill showing the exact time. Completing everything raises a confirmation toast - or the priority-review lift message where one applies.

```
my-react-app/src/Pages/DashboardPage.jsx
my-react-app/src/Pages/DashboardPage.css
```

Supplement tracker with adherence (NEW)

A dedicated daily-tracking page with today's supplements and the priority legend on the left, and a live overall adherence figure with an encouraging sentence and a per-day completed-over-total grid on the right. The page refreshes when the tab regains focus and immediately after a dose is marked.

```
my-react-app/src/Pages/TrackIntakePage.jsx
my-react-app/src/Pages/TrackIntakePage.css
```

Interactive month calendar (NEW)

A month calendar with previous and next navigation, a colour legend for today, 100%, partial and missed, future dates disabled, and per-day tooltips such as "3/4 supplements taken (75%) - click to view".

Clicking a past day opens a read-only detail panel: a taken-of-total summary with a perfect-day note at 100%, a per-supplement list with priority dot, dosage, best time or the exact time it was taken, and a taken or not-taken pill. Clicking the day again, clicking away, or clicking a future date closes it.

Below the calendar sit the current streak - shown as no active streak, one day, or N days - and the longest streak ever recorded.

```
my-react-app/src/Pages/TrackIntakePage.jsx
my-react-app/src/api.js
```

2.8 Insights and analytics (Deluxe and above)

Four-tab health insights (NEW)

TAB	CONTENTS
Overview	Four statistic cards (longest streak, adherence rate, wellness score, assessments completed), the member's current plan phase with its focus, action steps and expected changes, and lifestyle recommendations.
Today's progress	A large SVG progress ring colour-coded at 100% green, 50% and above amber, below that red, with a motivational headline and today's supplement grid including taken-at times.
Adherence	A colour-coded weekly bar chart with taken-of-total per day, plus every phase of the wellness journey listed and numbered.
AI insight	The current phase restated as AI-powered phase guidance with recommended actions and what to expect, plus personalised lifestyle tips.

A plan-gate refusal from the server swaps the entire page body for a locked card that lists what an upgrade buys, and the page re-fetches the instant the subscription changes.

```
my-react-app/src/Pages/InsightsPage.jsx
my-react-app/src/Components/PlanLockedCard/PlanLockedCard.jsx
my-react-app/src/api.js
```

2.9 Assessment history and records

Health timeline with search and status filters (NEW)

A header explaining that the latest active assessment powers the dashboard, the tracker and insights, followed by five summary tiles: assessments, active record, how many carry AI analysis, how many are flagged priority, and - where a record is within 180 days of expiry - the time until the next expiry.

Records are listed newest first with badges for active, expired, priority, age, diet, activity, symptom count and AI analysis. Browsing is supported by a free-text search that matches across date, headline, diet, age, activity,

symptoms, goals and conditions, plus a status lens of all, active or expired. Both filters are client-side views over the loaded page and cost no additional request.

```
my-react-app/src/Pages/HistoryPage.jsx
my-react-app/src/Pages/HistoryPage.css
```

Per-record actions and tabbed detail (NEW)

- **View assessment** - the read-only questionnaire described in section 2.4.
- **View results** - re-opens the full results page for that record.
- **Download PDF** - the same exported wellness report, gated client- and server-side.
- **Delete** - offered only on expired records, behind a styled confirmation dialog that frames it as reviewing an older assessment.

Expanded detail is tabbed per record: assessment (including computed BMI with its band), supplements (priority-sorted and expandable, with reason, dosage, timing, interactions, evidence, food sources and side effects, plus the avoid and warnings lists), schedule and recovery, meals, lifestyle, and warnings.

```
my-react-app/src/Pages/HistoryPage.jsx
```

Five-year record history with tier-capped paging (NEW, Premium and above)

Records are kept for five years and are never deleted. After five years a record takes an expired badge, drops out of the active dashboard, tracker and insights views, and becomes deletable; a priority record never expires while flagged.

The server caps page size by tier - five records for Free, ten for Deluxe, twenty for Premium and above - and gates page two onward behind the history entitlement. Members who qualify get a "Load older assessments" control with a showing-X-of-Y readout; members below the tier get an inline locked card naming the required plan and their current per-page allowance. The entitlement is therefore reachable rather than merely declared.

```
server/routes/assessment.js
my-react-app/src/Utils/plan.js
my-react-app/src/Pages/HistoryPage.jsx
```

2.10 Profile and personalisation

Cover banner and avatar (NEW)

The profile opens with a full-width cover banner and a circular avatar that straddles the cover edge. Identity sits on the card below the artwork, so a wide photo is never cropped to fit a name. In edit mode the banner gains a pencil control and a remove chip, and the avatar gains a camera overlay. Uploads are validated client-side at 2 MB for a profile picture and 3 MB for a banner, images only, with an instant preview and a friendly message if the server still refuses. The avatar falls back to an initial through a single shared component, keyed on the failing source so choosing a new picture can never stay hidden.

```
my-react-app/src/Pages/ProfilePage.jsx
my-react-app/src/Components/ProfileAvatar/ProfileAvatarImage.jsx
my-react-app/src/Utils/pictureUrl.js
```

Four profile cards selected from the account menu (NEW)

The profile shows one card at a time, selected through a URL parameter so the deep link is shareable and the browser Back button behaves: Personal Information, Account Security, Accounts, and Plan and billing. Anything unrecognised falls back to Personal, so the route always lands somewhere useful.

The Personal Information card carries a plan chip showing the customer-facing plan name and an explicit notice that date-of-birth and gender changes apply to future assessments only, so past records stay accurate. Changing the email address requires verification with a six-digit code, a ten-minute countdown, a sixty-second resend cooldown and expiry that disables the field.

```
my-react-app/src/Pages/ProfilePage.jsx
my-react-app/src/Pages/ProfilePage.css
```

Plan and billing card (NEW)

Answers the three questions a subscriber actually has: what plan am I on, how long is left, and where do I change it. Shows a source chip distinguishing a paid plan, an administrator grant and the free tier; a seats row when there is more than one seat; time remaining as permanent, a day count, expired, or no active subscription; renewal, expiry and start dates; and a change-plan action.

Where an administrator has overridden the plan, a note says so plainly and states that the member's own paid plan is untouched underneath and can be restored exactly. A footnote explains the period model honestly: a plan runs for the days shown, never renews on its own, and buying again adds to the days already remaining.

```
my-react-app/src/Pages/ProfilePage.jsx
my-react-app/src/Utils/plan.js
```

2.11 Plans, pricing and subscriptions

Four-tier plan model with strict inheritance (NEW)

Four plans, plus a Team band whose every seat grants Premium. Each higher tier is a strict superset of the tier below it, defined once on the server and mirrored on the client with a test that imports the real server module and fails the build if the two registries ever diverge.

TIER	UNLOCKS
Free	Health assessment, supplement recommendations, daily intake tracking
Deluxe	Adds insights and analytics, PDF report export, and the entire Web3 layer: wallet and supply chain, marketplace, DAO governance
Premium	Adds priority assessment and five-year record history
Ultimate	Adds the AI chat assistant and every remaining capability

```
server/Utils/entitlements.js
server/Utils/planCatalogue.js
my-react-app/src/subscription/features.js
my-react-app/src/subscription/features.test.js
my-react-app/src/Utils/plan.js
```

Public plan catalogue (NEW)

Deliberately public so a visitor can compare before signing up. The page carries a hero, a your-plan card for signed-in members with a period meter sized against the account's actual start-to-end window, and a sticky dock carrying a currency picker and a monthly or yearly toggle whose badge advertises the best saving across plans.

Prices are formatted server-side and the page never formats money itself, so a currency change cannot produce a client-side rounding discrepancy. Feature bullets on each card are derived from the entitlement gates, so a card can never advertise something the backend would not grant, and the real enforced limit is shown alongside them.

```
my-react-app/src/Pages/PricingPage.jsx
my-react-app/src/subscription/catalogue.js
```

Two-step checkout sheet (NEW)

Step one summarises what is being bought, for how long, for how much, and - the part members most often misunderstand - what happens to days already paid for, which is that renewing extends the window rather than replacing it. With self-serve billing enabled the purchase confirms instantly; with it disabled the proof-of-payment form is the primary action, because an administrator approving a receipt is the only route to a paid plan on that deployment. Either way there is never a button on screen that cannot succeed.

Step two renders a "pay to" block - account name, bank, account number, contact, instructions and reference - only when the server says a destination exists. When it does not, the copy says so plainly and points at the administrator route rather than inviting a payment nobody can receive. The receipt can be picked or dragged and dropped onto the box, accepting PNG, JPEG or WebP up to 2 MB with a live size readout and a preview.

The form checks for an existing pending request for the same plan before the upload begins, so a duplicate never costs a 2 MB round trip. On success the fresh subscription snapshot is published to the shared store before the sheet even closes, so the whole application unlocks without a refresh or a re-login.

```
my-react-app/src/Pages/PricingPage.jsx
my-react-app/src/subscription/sheetActions.js
my-react-app/src/subscription/paymentCopy.js
```

Cancellation sheet with two honest doors (NEW)

Pressing the Free card while on a paid plan opens a cancellation sheet - previously a dead button that navigated to the dashboard and changed nothing. Two radio doors are offered, and the commit button's label is derived from the chosen door so it always states the real consequence: ask an administrator, where the plan stays active until a human reviews it; or end it now, where the paid plan is removed immediately, the member returns to Free, and the unused days are not refunded.

The sheet warns if a review request is already waiting, and the fresh subscription is published immediately so every open tab drops to Free without a refresh.

```
my-react-app/src/Pages/PricingPage.jsx
my-react-app/src/subscription/cancelSheetActions.js
```

My plan requests and my cancellations (NEW)

Beneath the billing card a member sees the outcome of everything they have asked for. Plan requests show under review, approved or declined, with the term, the formatted amount, how long ago it was sent, the days granted on approval, and - for a decline - the reviewer's reason. Cancellations are a deliberately separate list,

waiting, ended or declined, so "waiting to be turned on" and "waiting to be turned off" can never be confused. Both lists render nothing at all when there is nothing to show.

```
my-react-app/src/Components/MyPlanRequests/MyPlanRequests.jsx
my-react-app/src/Components/MyPlanRequests/MyPlanCancels.jsx
```

Instant no-refresh entitlement sync (NEW)

A shared subscription store keeps the plan correct everywhere with no refresh, no re-login and no polling storm. A Server-Sent Events stream pushes every administrator upgrade, downgrade, cancellation and removal to open tabs across devices. A local expiry timer flips the plan to Free at the exact second the period ends rather than at the next poll. A BroadcastChannel relay between same-account tabs closes the gap if one stream is down. A single shared sixty-second throttled poll with focus refresh is the safety net, and a rate limit response pauses refreshing on an escalating sixty-second to five-minute to fifteen-minute cooldown rather than hammering into the lockout ladder.

The store is mounted in the router keyed by token, so switching accounts cannot inherit the previous account's plan, and it is torn down on sign-out. All of it funnels into a single commit that notifies subscribers exactly once per real change.

```
my-react-app/src/hooks/useSubscription.js
my-react-app/src/App.jsx
my-react-app/src/auth/authState.js
server/utils/subscriptionBus.js
```

Two payroll surfaces (NEW)

A small in-place upgrade modal names the feature being unlocked, the tier required and the tier currently held, offering "maybe later" and "view plans". A full-page locked card is used where an entire page is gated; it states the value first, shows the gap literally as your plan to required, lists what the upgrade buys, and offers exactly one dominant action. The locked state renders instead of the page, so a member below the tier never fires the panel's mount-time requests.

```
my-react-app/src/Components/UpgradeModal/UpgradeModal.jsx
my-react-app/src/Components/PlanLockedCard/PlanLockedCard.jsx
my-react-app/src/Components/Web3PlanGate/Web3PlanGate.jsx
```

2.12 Account security centre

A dedicated card group inside the profile, deliberately separate from the profile form so that fixing a typo never triggers password rules and changing a password never requires filling in profile fields.

Two-factor authentication with a method picker (NEW)

The card shows on or off and offers two methods as a radio group with strength labels: an authenticator app, labelled strongest, and email codes, labelled weaker with an explicit explanation that email codes protect the password but not an attacker who already has inbox access. Turning the authenticator on shows a QR code to scan and a field to confirm.

Switching away from a live authenticator requires the current password, because it removes a stronger factor. Turning two-factor off entirely requires a current authenticator code, or the password where email codes are the active method.

```
my-react-app/src/Components/ProfileSecurityControls/ProfileSecurityControls.jsx
```

my-react-app/src/Pages/ProfilePage.jsx
my-react-app/src/api.js

Change password with a last-changed read-out (NEW)

A dedicated card carries a permanent last-password-changed read-out - today, N days ago, a date, or never recorded - alongside the exact timestamp. The form requires the current password, a new password meeting the policy, and a confirmation. Changing it signs out the member's other devices.

IMPLEMENTATION DETAIL WORTH RECORDING

The form container is a div with an explicit key handler rather than a nested form element. The HTML parser silently drops a nested form's start tag, which had disarmed the submit button - a defect that was invisible until the key handler was traced.

my-react-app/src/Components/ProfileSecurityControls/ProfileSecurityControls.jsx
my-react-app/src/api.js

Single-use recovery codes (NEW)

A batch of single-use codes in XXXXX-XXXXX form can be minted at any time. The view warns that each code works once and cannot be shown again, offers copy-all with a fallback for contexts where the clipboard API is refused, and requires an explicit confirmation that the codes were saved before they can be dismissed. Remaining and total counts come from the server summary, which knows about redemptions already made at sign-in; a failed summary fetch renders as unknown rather than falsely reporting that none exist.

my-react-app/src/Components/ProfileSecurityControls/RecoveryPanel.jsx
my-react-app/src/Components/ProfileSecurityControls/RecoveryPanel.test.js
my-react-app/src/api.js

Recovery email (NEW)

A secondary recovery address - the one the owner would be warned through - can be added, verified with a one-time code and removed, with a masked display and the same step-up requirement as every other lasting change.

Signed-in devices (NEW)

A list of the devices this account can see, each with a friendly label such as "Chrome on Windows", the platform, location, IP address and timestamps, a chip marking the current device, and per-row revoke. A sign-out-all-other-devices action is also available. Revoking removes that session everywhere immediately.

my-react-app/src/Components/ProfileSecurityControls/SessionActivity.jsx
my-react-app/src/api.js

Security activity feed (NEW)

An append-only event log rendered with seventeen labelled event types: signed in, signed in from a new device, failed sign-in, second factor accepted or rejected, two-factor enabled or disabled, password changed, incorrect password, recovery codes created, invalidated or used, session revoked, all other sessions signed out, device removed, recovery email changed, and sign-in temporarily paused.

Notable events are highlighted, and the wording is deliberately even-handed - a failed sign-in is recorded as a failed sign-in, never as an attack. The profile also surfaces the newest five security notices as a click-to-read feed with an unread treatment. The feed shows eight events by default with a view-all toggle.

WHY THE WORDING MATTERS

This feed replaced browser-side title string matching, which silently dropped any event whose title did not match a hard-coded pattern. The server now returns a structured event type for every row, so nothing can be lost to a wording change.

Step-up confirmation (NEW)

A live session is not enough to change a security setting. Anything lasting - turning two-factor off, minting recovery codes, repointing the recovery email, revoking devices - raises a confirmation dialog asking for the current password, plus the authenticator code where that is the active factor, traded for a short-lived session-bound five-minute token. Step-up earned on one device does not authorise a change from another, and a fresh sign-in invalidates it.

```
my-react-app/src/Components/ProfileSecurityControls/StepUpDialog.jsx  
server/routes/security.js
```

2.13 Notifications

Notification bell with a smart dropdown (NEW)

A bell in the navbar carries an unread badge capped at 9+. The panel opens on hover with a 200-millisecond grace period so the pointer can cross the gap between bell and panel, and on click; it re-anchors on scroll and resize so it stays pinned to the bell.

- Mark all as read, delete all read behind a styled confirmation dialog - deliberately not the browser confirm dialog, which the Android web view swallows - and per-item delete.
- Opening an item marks it read and deep-links: security notices open the account security card, flagged assessments open history.
- Polls every sixty seconds and refreshes on tab focus.

```
my-react-app/src/Components/UserNotifications/UserNotifications.jsx  
my-react-app/src/api.js
```

2.14 Human support inbox

Threaded, status-coloured conversations (NEW)

A dedicated support route, requiring a session, is the human channel and is deliberately separate from the AI assistant. The layout is two panes and collapses to one on a phone.

- **Composer** with five colour-coded topics - payment, billing and plans, account, technical, something else - an optional subject capped at 160 characters and a message capped at 2,000 with a live remaining count.
- **Conversation list** with unread counts, last-message preview, relative time, and four client-side filters with live counts: all, with support, your turn, resolved.
- **Thread view** with day separators, author and timestamp shown only on the first message of a run, an auto-growing reply box where Enter sends and Shift+Enter inserts a newline, and a fixed-height transcript so the reply box is always on screen.

- A resolved thread is read-only with an explanation and a start-a-new-conversation button. There is deliberately no reopen action, because resolving and reopening are administrator actions and offering one would only produce a conflict response.
- Polling every twelve seconds while the tab is visible, pausing while a send is in flight, and discarding replies for a thread the member has left. Deep-link parameters preselect the topic and open the composer, which is how the checkout sheet's "talk to support" hands off.

```
my-react-app/src/Pages/SupportChatPage.jsx
my-react-app/src/Components/SupportInbox/SupportInbox.jsx
server/routes/supportChat.js
```

2.15 AI chat assistant (Ultimate)

Floating assistant with live connection state (NEW)

A floating edge tab on the right of every member page. It is hidden on the sign-in and registration pages, on every administrator route, and on the support page so it can never be mistaken for the human channel; it also stands down while the account menu is open so it cannot swallow taps on a phone.

The panel shows a header with a live connection state - online, connecting, reconnecting, busy or unavailable - a welcome message and six quick prompts covering how to start an assessment, what the confidence score means, what a named supplement is, whether supplements can be mixed, how to view history, and what a priority rating means.

```
my-react-app/src/Pages/ChatAssistant.jsx
my-react-app/src/Pages/ChatAssistant.css
```

Markdown rendering and safe conversation handling (NEW)

Replies render Markdown - headings, bullet and numbered lists, tables, bold, italic, code and rules - through a dependency-free renderer that is memoised so a long transcript is parsed once per message. Conversation context is the last eight successful turns, with error bubbles excluded so interface state can never poison the model. Messages cap at 1,000 characters.

The transcript only auto-scrolls while the reader is already at the bottom; a jump-to-newest control appears otherwise, and the composer is re-focused on each reply except on coarse pointers. Signing out or switching account resets the transcript and closes the panel, and an in-flight reply from the previous account is discarded.

```
server/routes/chat.js
my-react-app/src/utils/overlayRegistry.js
```

Gating and honest failure states (NEW)

The assistant is gated on the chat entitlement. Guests see a log-in or create-an-account screen; members below the tier see an in-panel paywall naming the plan with a view-plans control, and a stale paywall clears itself the moment the plan qualifies. A server-side fallback answer is shown with a reconnecting state rather than being passed off as a live answer.

Panel layout defects corrected (FIXED)

SYMPTOM	ROOT CAUSE	CORRECTION
Panel header cut off above the viewport	A 580px maximum height combined with a 90px bottom offset needs 670px of viewport; any shorter window pushed the top off-screen	Maximum height is now the smaller of 580px and the viewport minus 110px, with the same treatment applied to the narrow-screen rule
Horizontal scrollbar across the chat	Overflow-y auto makes overflow-x compute to auto, and nothing set overflow-wrap, so one long URL widened the transcript	Overflow-x hidden, overflow-wrap anywhere on message bubbles, zero-height WebKit scrollbar, overscroll behaviour contained
Jump-to-newest arrow floating over the wrong element	A hard-coded bottom offset was correct only while the chip rows stayed one line tall	A positioned wrapper anchors the button inside the scroll region, making the offset structural rather than magic
Page behind the chat jumped while scrolling	Two effects fought - one scrolled every ancestor including the document, the other reset the scroll position	A single effect scrolls the container directly, follows the typing indicator and re-focuses the composer
Composer could not shrink	A flex item's default minimum width pinned the input to its intrinsic width	Minimum width zero on the flex item
Upgrade modal triggered a full page reload	A hard navigation was used instead of client-side routing	Client-side navigation to the profile page

3. Web3 and Blockchain Layer

A twenty-feature permissioned blockchain embedded in the product, gated to the Deluxe tier and above. It is the largest single subsystem added in this release.

NON-NEGOTIABLE PRIVACY RULE

Only SHA-256 digests, counts and coarse bands are ever written on-chain. Health data, identifiers and free text are never anchored. This rule is stated in the developer manual, enforced in the state engine, and independently verified by the live security monitor.

3.1 Foundation

COMPONENT	RESPONSIBILITY
Cryptography	Stable string serialisation, SHA-256, ed25519 identity, AES-256-GCM encryption and decryption, content-addressed bafy-style identifiers, base32 encoding
Ledger	Append-only proof-of-work chain at difficulty 3, a verifier with a five-second budget, and a background full re-hash every five minutes; whole-chain re-hash runs off the hot path so only new blocks are checked inline
State engine	The only place Web3 state mutates. The database is written first and the change is anchored second; an anchor failure is logged and never rolls back. Availability is chosen over perfect atomicity, and the choice is documented
Rules	Pure, unit-tested contract rules with no database, network or model dependency
Seed	Idempotent genesis bootstrap
Identity	A decentralised identifier per user and a deterministic address derived from the public key. Private keys are sealed in an AES-256-GCM envelope derived from the server secret; export returns a standard PKCS#8 PEM, owner-only
System wallets	Treasury, escrow, brand and expert-pool wallets

3.2 Web3 hub - eight tabbed panels

One route hosting eight panels, each remounted with a fresh key on tab switch so the interface always reflects current chain state. A shared component kit supplies spinners, empty states, alerts, statistics, copy chips, hero headers, area navigation, tab bars and formatters.

PANEL	CAPABILITY
Wallet and identity	Automatic wallet creation on first open with a 100-token welcome bonus; a decentralised identifier, address, public key, balance and staked amount; private key export with an explicit warning; and the governance-defined protocol parameters
Rewards and NFTs	Token rewards for healthy habits - a streak-scaled daily check-in, an intake reward paid only when a real intake record exists, and a one-off assessment reward. Achievement NFTs are computed server-side from real activity and are soulbound: earned once, never re-minted. Staking earns yield on activity and progresses toward the governance threshold; a loyalty programme burns tokens for a single-use discount code; every reward row links to the chain explorer
Health ledger	A rolling digest over real assessments and intake history plus chain-anchored snapshots; a signed, verifiable health credential export; restore from decentralised storage; and an anchor history with a once-daily cost
Privacy and data	Share anonymised data and earn a reward - the dataset is built server-side from coarse bands only, encrypted, content-addressed and consented on-chain, and revoking destroys the stored payload. Data-share consents are listed. Health profile share links for doctors and nutritionists are time-boxed
AI proof	Answers "why was I recommended this" by anchoring the recommender's input, its output and its logic version separately, then recomputing all three so an after-the-fact edit fails verification. An audit trail accompanies it
Trials and oracles	Decentralised oracle feeds re-derived daily and anchored on change, also shown beside marketplace prices. Secure clinical trial participation hashes the exact terms - sponsor, data scope, revocability and reward - and anchors them, with withdrawal also anchored and one consent per trial. Tokenised access to health professionals books by the hour with a full refund on cancellation
Supply chain	Register a new batch, which mints a verification code; list my batches with forward-only journey steps and certifications; and a link out to the public verification experience
Block explorer	Chain tip and difficulty, transaction lookup by hash, recent blocks, and a verify action that recomputes every block hash from scratch

3.3 Marketplace with escrow

Four tabs: browse, my orders (bought and sold), sell, and disputes. Categories span vitamins, minerals, herbs, protein, probiotics and other. Listings show a token price, stock and an oracle reference price. A clamped quantity stepper - decrement, increment and a typed value - is pinned by a test so the stepper and the buy button can never disagree.

- **Buying** locks funds in an escrow wallet so the seller cannot touch them before delivery is confirmed.
- **Confirming delivery** executes the contract and pays the seller minus a three percent protocol fee to the treasury.
- **Disputes** draw independent jurors from staked wallets that are not a party to the trade; parties are refused a vote. The appointed panel resolves by majority, a tie pays nobody, and jurors are compensated. A buyer verdict refunds in full and restores stock; a seller verdict releases escrow.
- Loyalty codes apply at checkout and are single-use.

```
my-react-app/src/Pages/MarketplacePage.jsx
my-react-app/src/Pages/marketplaceQuantity.js
my-react-app/src/Pages/marketplaceQuantity.test.js
```

3.4 DAO governance and community knowledge base

Three tabs: proposals, new proposal, and a knowledge base. A governance-at-a-glance card shows the member's voting weight - free balance plus anything staked, as a single number applied to every vote - the voting period in days, the quorum weight and the count of active proposals.

Proposal cards show status, the parameter a proposal would rewrite, a for-share bar that reads zero until someone votes so it never implies unanimous support, whether quorum is met, the voter count, a live countdown and the member's own vote where cast. Drafting requires a title of at least six characters and a description of at least ten, and a balance or a stake is required to propose. Passing a proposal actually applies the parameter and anchors the execution.

The knowledge base lets members publish a product review, research finding or success story and earn tokens, and upvote others; self-upvotes and double upvotes are rejected.

```
my-react-app/src/Pages/GovernancePage.jsx
```

3.5 Reward safety and integrity guarantees

- Every reward is idempotent at the database level on user, kind and reference, so a double click or a retried request can never mint twice.
- NFTs carry a unique owner-and-kind index; a concurrent mint is treated as already owned.
- Staking APY is pro-rated on activity through a conditional last-accrual update.
- The chain is verified on the hot path for new blocks and re-hashed in full every five minutes; a chain-integrity failure names the specific block index.
- Administrator tokens are rejected from the Web3 API entirely.
- Share links are time-boxed between one and 720 hours, revocable, view-counted, and carry a not-a-diagnosis disclaimer.
- Data shares are coarse and revocable, and revocation destroys the stored dataset.

```
server/blockchain/ledger.js
server/blockchain/engine.js
server/models/Web3.js
server/utils/attack_probes.js
```

4. Administrator Console

An eight-tab control panel with a live security monitor, real AI provider probing, two subscription review queues, a support inbox, assessment management with a priority override, and self-service account management. Forty-three endpoints sit behind the administrator middleware.

4.1 Administrator authentication

Two-step sign-in - credentials then authenticator (NEW)

Administrator sign-in is entirely separate from member sign-in. The first step posts an alias and password and returns an opaque challenge identifier, never a token. The second step posts the six-digit authenticator code, and is the only route that mints an administrator token. A stolen password alone is therefore worthless.

- Authenticator replay protection is scoped per account, with a ninety-second one-time-use cache keyed without the clock step. Scoping per account fixed a real defect where two administrators sharing one seed consumed each other's codes and only one of six could complete verification per window.
- A lockout ladder applies to both steps with rungs of fifteen minutes, one hour, six hours and twenty-four hours, with a thirty-day offence decay so a clean month resets the ladder.
- Legacy bcrypt hashes that verify are transparently re-hashed to argon2id on successful login, with no downtime.
- A legacy environment-variable configuration is supported for deployments that have not yet migrated to administrator account records.

```
my-react-app/src/Pages/AdminLogin.jsx
server/routes/auth.js
server/utils/adminAccounts.js
server/utils/totp.js
server/models/AdminAccount.js
```

Forced password change for temporary credentials (NEW)

An administrator whose password was generated for it may authenticate but may do nothing else until it chooses its own. This is enforced in server middleware rather than by a client redirect, so a copied token or a direct request cannot bypass it.

- A 403 with a machine-readable code - deliberately 403 rather than 401, so a valid token is not discarded by the client.
- The allowlist is matched on exact method and path with the query string excluded, so a crafted parameter cannot widen it. Only the password change and a session-status read are permitted.
- The session-status read returns the live password rules so the forced screen renders the server's checklist rather than a client-side copy.
- A mistyped authenticator code is an inline error, never a logout loop: the screen only signs out on genuine session-end codes.

A single shared password policy - ten to 128 characters, one character from each of upper case, lower case, digit and symbol, plus a guessability check - replaced three hand-written copies that had drifted apart.

```
server/middleware/auth.js
server/utils/passwordRules.js
my-react-app/src/Components/AdminProtectedRoute.jsx
my-react-app/src/Pages/AdminChangePassword.jsx
```

Sliding session with idle kill and a live countdown (NEW)

SETTING	VALUE
Idle limit	10 minutes
Token lifetime	15 minutes
Heartbeat interval	5 minutes (half the idle window)
Warning modal lead time	60 seconds before expiry
Dashboard poll interval	10 seconds

The ordering invariant - heartbeat shorter than the idle limit shorter than the token lifetime - is asserted at import time, because a five-minute heartbeat against a shorter window killed continuously-active administrators roughly every four minutes.

The console badge counts down the server's number, learned from the API rather than guessed at compile time, and runs its own half-second ticker so the whole dashboard does not re-render two hundred times per idle session. Background polls deliberately do not keep the session alive, so an idle administrator's own polling cannot postpone their logout.

```
server/utils/adminSession.js
server/middleware/auth.js
my-react-app/src/Pages/AdminDashboard.jsx
my-react-app/src/Components/SessionExpiryModal/SessionExpiryModal.jsx
```

4.2 Console shell and navigation

Eight tabs plus a profile panel (NEW)

Overview, user management, admin management, subscription management, chat management, assessment management, AI management, and security. A ninth panel - the administrator profile - is reachable only from the avatar menu. The sidebar collapses to a 64-pixel icon-only rail and persists that choice, with tooltips and accessible labels always present because narrow viewports hide labels independently.

Resilient dashboard refresh (NEW)

Five panels refresh every ten seconds, on window focus and on tab visibility. Each lands independently through an all-settled group, so one slow endpoint no longer freezes the whole dashboard, and only genuinely failed panels are reported. A request-overlap guard prevents stacking, and a browser-level "failed to fetch" is rewritten into plain language. Cached avatars are re-attached to the recent-users preview, which the server omits from that projection because the image field cost 668 ms of a 783 ms endpoint.

```
my-react-app/src/Pages/AdminDashboard.jsx
my-react-app/src/Components/AdminTopbar/AdminTopbar.jsx
```

4.3 Overview and analytics

Four metric cards (NEW)

Total users with a paid-versus-free breakdown, total assessments with a fourteen-day count, active subscriptions as a share of members, and inactive subscriptions as a share of members. Each card has its own colour palette and a loading skeleton so the grid never reflows.

CORRECTNESS RULE WORTH RECORDING

"Active" is defined as subscription active, plan not free, and either permanent or with no expiry date or an expiry date in the future. Counting the bare active flag overstated the metric by every silently expired subscription.

Assessment activity chart (NEW)

A fourteen-day bar chart computed from a database date aggregation, showing the window total, the daily average, a highlighted peak day, gridlines derived from a single tick list so labels and lines cannot drift, per-bar tooltips, an accessible summary, and a proper empty state.

Plan mix donut (NEW)

A donut for Free, Deluxe, Premium and Ultimate with counts, percentages and progress tracks. The free tier is derived as total minus paid so the four rows always sum to the whole.

Security and growth tiles (NEW)

Two-factor adoption with a share-of-total meter, a locked-now tile that turns rose when any account is held, and new-member counts over seven and thirty days.

Recent activity table and threat panel (NEW)

The latest eight registrations with a deterministic-colour avatar, name, address, join date, resolved subscription badge, and a two-factor method badge that distinguishes an authenticator from email codes. Alongside it, a threat panel listing every non-secure configuration check, or an all-systems-secure panel when there is nothing to report.

```
my-react-app/src/utils/adminOverview.js  
my-react-app/src/utils/adminOverview.test.js
```

4.4 User management

Search and filter-as-stat-cards (NEW)

Instant search across address, first name and last name with a 400-millisecond debounce; regular-expression metacharacters are escaped server-side and the term is capped, closing a regular-expression denial-of-service vector. Four stat cards double as the filter - all, active, locked out, banned - with counts derived from the fetched result set so a card can never disagree with the list beneath it.

Row detail and device attribution (NEW)

The collapsed row shows the avatar, name, address, resolved plan, join and last-seen timestamps, and a state pill. Expanding reveals last login with parsed device naming, location resolved from the address in the background, subscription detail, account role, account status, two-factor method and lockout status.

Live lockout countdown and unlock (NEW)

A one-second ticker counts down against the fetched lock state, with wording that adapts as the remaining time drops. The tooltip lists the evidence addresses and whether the hold is network-scoped or account-scoped. Unlock clears every lockout bucket - address, one-time code, last-sign-in address in both raw and normalised forms, all evidence addresses and the administrator's own address - writes an audit row, and fires both an in-application notification and a status email so the member knows immediately.

Ban and unban with member notification (NEW)

Account status can be set to active or banned. Only an actual transition sends the member an in-application notification and an email, so a repeated save does not spam.

Cascading account deletion (NEW)

A hard delete derived from the schemas: sessions are removed first so a refresh cannot resurrect the account mid-delete, then every user-owned model is cleared across each object identifier field, covering assessments, notifications, subscription requests and cancellations, intake records, dashboard metrics, chat threads and messages, and all twenty-two Web3 collections. The user row is deleted last and the audit row is deliberately retained with its dangling identifier.

```
my-react-app/src/Pages/AdminDashboard.jsx  
my-react-app/src/Components/AdminSubscriptionPanel/AdminSubscriptionPanel.jsx  
server/routes/admin.js
```

4.5 Administrator management and credential operations

Secret-free administration list (NEW)

A dedicated hero and queue listing administrators by alias only - the alias is the entire administrator identity; there is no separate administrator address sign-in. The endpoint projects only alias, enabled state and timestamps, so password hashes and authenticator secrets are never sent to the page and therefore cannot be displayed there. A standing strip on the panel states this.

Self-protection and last-administrator guard (NEW)

The current-administrator check matches on alias rather than identifier, because the profile endpoint does not return an identifier. Disabling your own account is not offered, the server refuses it, and the server also refuses to disable the last enabled administrator.

Credential-update notice - secret-free (NEW)

A recurring email telling every configured administrator that the stored form of their credentials changed. It deliberately carries no password and no authenticator key, because this project's real seeds were once committed to a public repository.

- A preview endpoint returns the exact sentence and the exact recipient list before anything is sent.
- The send endpoint enforces a sixty-second cooldown, caps the description at 400 characters, refuses a caller-supplied recipient list - which would otherwise make it an open relay with an audit trail pointing at whoever pressed the button - and answers 207 Multi-Status on partial delivery.
- The console reports delivered, failed and missing-address lists.

One-time credential hand-off - carries secrets, kept separate (NEW)

Emails each administrator their own alias, password and authenticator key exactly once. It is a separate endpoint, module and cooldown from the recurring notice, precisely so that nothing can widen what the recurring notice is able to send.

- The preview returns booleans describing whether a key exists, never the seed itself.
- The send endpoint enforces a ten-minute cooldown, rejects caller-supplied recipients, and answers 207 on partial delivery.
- The password map accessor returns only aliases and a count. Values are never logged, echoed in an error, or written to an audit row.
- Passwords are not trimmed, because leading and trailing spaces are characters the administrator chose; an all-whitespace value is reported as not filled in.
- Aliases with no configured authenticator key are blocked before the operator types anything.
- Sends are sequential rather than concurrent.
- The dialog opens with empty password state every time and clears it unconditionally on close.

```
my-react-app/src/Pages/AdminDashboard.jsx
server/utils/adminAccounts.js
server/utils/adminCredentialNotice.js
server/utils/adminCredentialHandoff.js
```

4.6 Subscription management

Two-queue review switcher (NEW)

Plan requests and cancellations are separate components behind a queue switcher, precisely so a confirmation dialog can never branch and cancel someone's plan while intending to approve a purchase.

Plan request review (NEW)

- Four filter cards with counts: pending, approved, declined, all.
- Card facts: the plan requested, the term in months, the amount due colour-weighted because that is what a reviewer scans for, the submitted timestamp and relative age, the payment reference, the member's note, and a banned flag when the account is not active.
- The proof image is fetched on demand, one at a time - twenty-five inline receipts would be tens of megabytes per poll.
- Reviewer controls: days to grant, defaulting to the term multiplied by thirty but honouring a typed override, and a note to the member.
- The confirmation states the exact outcome before the button fires.

- **Exactly once by atomic claim** - the row is flipped from pending to approved with the granted plan, granted days and reviewer details written before any entitlement is granted. A lost race returns 409; a failed grant releases the claim; a missing account closes the row as rejected rather than leaving it pending forever.
- Days are bounded to 3650 so a typo or a tampered panel cannot mint a decade of access.
- Seat counts are preserved for team accounts.
- Opt-in full subscription controls for the account, mounted only when the reviewer asks.

Cancellation review (NEW)

- Filter cards for pending, applied, declined and all.
- Row facts include the plan being ended, the request timestamp, the route - whether the member asked for this or ended it themselves - the reason, the reviewer and note.
- Approving runs the same engine action the member's immediate path runs, through the same atomic claim.
- A dedicated non-shared confirmation states that the change removes paid access immediately, cannot be undone from that screen, and does not refund days already paid for.

Per-account subscription control panel (NEW)

The account's subscription is rendered as three clearly separated layers: the effective state, the user's own paid plan, and any administrator override. The paid layer is frozen the moment an override is applied, which is what makes a later restore exact.

CAPABILITY	DETAIL
Restore original state	Returns the exact captured snapshot including the original expiry date and the captured days remaining - not a fresh thirty days. The restore target is spelled out in the administrator's own words before the button is pressed
Ten engine actions	Grant, remove, add days, deduct days, extend, make permanent, change plan, restore, clear override, and set paid
Effective state header	Plan, source, permanent and status chips, a lapsed record marker, remaining time, expiry, start and period, a seats row, and a time-remaining progress bar
Day arithmetic	Add or deduct 1 to 3650 days, make permanent, change plan, and set an expiry date from a picker seeded from the current expiry on every load and re-seeded after each action
The user's own purchase	Record a paid month, cancel the paid plan, and edit seats from 1 to 500 - with a seat-passing path so a ten-seat account is not silently downgraded to one
Change log	Every action with its note, actor and timestamp, plus a from-to plan transition
Instant propagation	Every mutation publishes the new authoritative state on the subscription bus, so the member's open tab unlocks without a refresh, a re-login or a poll. The response also returns the authoritative user document, which is patched into the user list in place so a just-saved plan is never overwritten by a racing poll

Destructive actions - remove subscription, cancel the paid plan, restore the original - all route through a styled confirmation dialog.

```
my-react-app/src/Components/AdminSubscriptionRequests/AdminSubscriptionRequests.jsx
my-react-app/src/Components/AdminSubscriptionCancels/AdminSubscriptionCancels.jsx
```

```
my-react-app/src/Components/AdminSubscriptionPanel/AdminSubscriptionPanel.jsx
server/utils/subscriptionState.js
server/utils/subscriptionBus.js
```

4.7 Support chat management

Two-pane inbox (NEW)

A queue on the left and the conversation on the right - deliberately not the expand-a-row pattern used elsewhere, because answering a conversation means reading the last three messages while keeping the queue in view.

- Threads are sorted by last message time rather than update time, so a status change cannot float a dormant conversation above a live one.
- Four stat cards that are the filter - waiting on us, waiting on member, resolved, all - plus an unread banner, a category filter and a search across member name, address and subject because administrators are routinely asked to find the thread about a specific transfer.
- Reading a thread marks it read server-side.
- The transcript shows author names, timestamps, and a jump-to-latest pill when scrolled up, without yanking the view back down.
- Rows are navigable by keyboard: up and down move the selection and Escape returns to the queue, suppressed while typing.
- A styled skeleton and a three-bubble loading animation; polling every twelve seconds, paused when the tab is hidden or a send is in flight.

Administrator-only lifecycle actions (NEW)

ACTION	BEHAVIOUR
Reply	Replies as an administrator. Refused with 409 on a resolved thread - administrators are not exempt. Fires a member notification and auto-assigns the thread to the replying alias
Resolve	Freezes the thread for both sides, zeroes both unread counters, stamps the resolver, and notifies the member. Idempotent
Reopen	The only way back in. Returns the thread to waiting-on-us, clears the stamp, reassigns and notifies
Assign	Claim for an alias - informational only, never gating reading or replying, so colleagues can cover each other
Delete	Removes the thread and its whole transcript. Reserved for spam or abuse; the confirmation says so explicitly, because resolving keeps the record

DESIGN DECISION

Administrators cannot edit or delete an individual message. The transcript is the record. A separate route file is the only place a conversation can be closed or reopened - the member-facing router has neither endpoint, deliberately.

```
my-react-app/src/Components/AdminSupportChats/AdminSupportChats.jsx
```

```
server/routes/adminSupportChats.js
server/utis/supportChat.js
server/models/ChatThread.js
```

4.8 Assessment management

Member and assessment browsing (NEW)

Header statistics for members on the account, how many have been assessed, total assessments on record and the per-member average. A searchable member list with an assessment-count pill that is muted when there is nothing to read. Each assessment card shows an active or expired pill, a priority pill with its reasons in the tooltip and inline, the created timestamp, a symptom summary, and tag pills for age, diet, activity, symptom count and AI analysis.

Expiry uses the stored expiry, falling back to creation plus five calendar years - the same advance the server writes. A priority assessment shows "no expiry - resolves on completion".

Four per-assessment actions (NEW)

ACTION	BEHAVIOUR
View	The full recorded questionnaire in a read-only viewer
Results	The AI report for that assessment
PDF	A client-side report export built from the canonical assessment snapshot, so the report's identity and date are stable across regenerations
Modify	Correct what was recorded, with deletion available

Priority override (NEW)

An administrator can raise or release priority on any assessment. Raising is gated: when the day's plan is already complete or another review is open, the request is refused with a structured response identifying the intake and the open assessment. That gate closed a dead end where a member was told new assessments were paused with no route back.

- Raising suspends expiry; releasing restores the five-year window counted from creation, never five years from the moment of release.
- Releasing a record that is already standard is a genuine no-op, so an administrator decision is not overwritten by the automatic intake-completion rule.
- Only an actual change sends the member a notification and writes an audit row; a failed notification or audit never fails the override, and a failed write is an error rather than a silent success.

```
my-react-app/src/Pages/AssessmentManagement.jsx
my-react-app/src/Components/ReadOnlyAssessment/ReadOnlyAssessment.jsx
my-react-app/src/Components/AssessmentResultsDisplay/AssessmentResultsDisplay.jsx
my-react-app/src/Components/ModifyAssessmentModal/ModifyAssessmentModal.jsx
server/utis/priorityGate.js
server/utis/priorityRules.js
```

4.9 AI management and control

Live provider probing (NEW)

Every AI provider the platform can talk to is probed with a real request rather than read from an environment variable, because a key can exist and still be revoked, unreachable, or never called. Each card shows a monogram, label, environment key name, status, round-trip latency, a server-supplied detail sentence, the model, and - importantly - which route in this server actually calls it.

STATUS	MEANING	TONE
Reachable	A real request succeeded	Positive
Key rejected	The provider refused the key	Critical
Provider error	The provider returned an error	Critical
Unreachable	The provider could not be contacted	Critical
Model unavailable	The key works but the model does not exist	Critical
Not configured	No key present - optional, deliberately not painted as a failure	Neutral

Model-unavailable is its own state because "add a key" is the wrong advice there, and reporting it as reachable would hide a completion that is guaranteed to fail.

Check now with environment reload (NEW)

- A check action reloads the environment file from disk before re-probing, because the loader reads that file once at boot - a freshly rotated key was otherwise reported as rejected while being perfectly valid.
- The reload receipt names the variables applied or removed, never their values, and a failed reload is reported explicitly so the administrator does not conclude their key is broken.
- A stale-configuration banner appears when the running process disagrees with the file.
- The reported check time is the oldest probe in the batch, so a fresh-looking header cannot date a stale card as just-checked.
- Placeholder values are treated as unconfigured rather than as credentials.
- A background poll deliberately does not reload, so a half-typed environment file is never read.

STATED LIMITATION, PRINTED IN THE INTERFACE

Token usage and accuracy are not connected to provider usage APIs, so this panel reports live reachability and configuration state only. It is not a billing or quality report.

```
my-react-app/src/Pages/AdminDashboard.jsx
server/utils/aiProviders.js
server/utils/envFile.js
```

4.10 Security centre

Forty-five live monitors (NEW)

The server re-probes every check on demand. The panel polls every thirty seconds and schedules the next poll only after the previous one completes, so checks never stack. Each probe is capped at ten seconds server-side and twenty seconds client-side, results are cached for sixty seconds, and a run in which any probe timed out is never cached.

BAND	COUNT	COVERAGE
Core platform protections	24	Identity, transport, data and AI: login, account creation, email codes, authenticator, database, AI provider, account deletion, input sanitisation, password hashing and salting, stored cross-site scripting, NoSQL injection, path traversal, prototype pollution, brute-force resistance, stateless cross-site request forgery, prompt injection, personal data in AI prompts, AI quota, token security, security headers, email enumeration, sensitive data, rate limiting and lockout
Blockchain layer	21	Ledger and every Web3 feature probed live: ledger, supply, certifications, escrow, market, wallet, health ledger, data consent, storage, rewards, NFTs, staking, loyalty, governance, knowledge base, disputes, share links, AI proof, trials, oracle feeds and expert bookings

Each row shows a status pill, a framework chip, a full description, the exact source files implementing the control, the probe latency in milliseconds, and an expandable detail row with the full probe result and timestamp. Search spans label, key, implementation file, framework and detail; status chips, a framework filter, expand and collapse all, a "showing N of 45" readout and a clear-filters control sit above the list.

These are genuine invariant audits, not static declarations. Examples recorded during this release:

- NFT uniqueness is critical if the record count differs from the distinct token count.
- Staking is critical if any wallet holds a negative staked balance.
- Wallet integrity is critical if any wallet is missing its encryption key envelope.
- Storage integrity is critical if any stored object is missing its ciphertext, IV or auth tag.
- Oracle staleness is a warning when the oldest feed exceeds forty-eight hours - using the newest would let one dead feed hide behind five live ones.
- Governance is a warning when a protocol parameter is missing from the configuration.
- The personal-data-in-AI-prompts check re-scans the recommendation source on every run, so a field added to the prompt in a later commit cannot slip through unnoticed.

Security audit record (NEW)

A permanent, machine-readable record of the thirty-finding audit is served alongside the monitor response and rendered in full: severity breakdown, the six-phase method, headline findings with status, the changes applied, open and accepted items, automated verification results, a loud manual-action block, and the disclaimer verbatim. It never claims the application is one hundred percent secure.

FIELD	VALUE
Audit identifier	SEC-AUDIT-2026-09-23
Findings	30 (2 Critical, 8 High, 9 Medium, 7 Low, 4 Informational)
Remediated in code	23
Open and accepted	7 (3 Low, 4 Informational)
Manual actions outstanding	10 (4 urgent, 5 operational, 1 re-run)

Configuration posture and report export (NEW)

A posture endpoint returns five configuration checks with status, a fix sentence, an overall status, prioritised recommendations and notification rows: a strong token signing secret, administrator multi-factor configured, administrator passwords stored as argon2id, email delivery configured, and production environment safeguards - where the live control is that the development one-time-code response flag is not enabled, and a production boot hard-fails if it ever is.

A branded PDF report can be downloaded from the security centre. The PDF library is loaded dynamically so the roughly 350 KB it costs is kept out of the administrator bundle.

```
my-react-app/src/Components/SecurityStatus/SecurityStatus.jsx
server/routes/admin.js
server/utils/securityAudit.js
server/utils/attack_probes.js
my-react-app/src/utils/securityReport.js
```

4.11 Administrator profile

Vibrant redesigned account panel (NEW)

A deep gradient hero card with blurred radial glows, an amber-to-red gradient avatar tile, an administrator pill and two glass statistic cells for last login and membership since. Section headers carry gradient icon chips. Panels have an eighteen-pixel radius, a colour-coded top rail, lift-on-hover and a staggered entrance. Forms have tinted per-panel labels, rounded inputs, hover and focus rings, and a stronger visible-focus ring for keyboard users. Buttons are full-width gradient pills with lift and press states and a defined disabled appearance.

Responsive stacking below 640 pixels, plus a reduced-motion guard.

DEFECT FOUND AND FIXED WHILE REDESIGNING THIS PANEL

The member profile stylesheet and the administrator dashboard stylesheet both defined profile-page, profile-form and profile-alert. Both stylesheets land in the same document, so whichever chunk loaded last won - the administrator rules could restyle the member page or vice versa. All roughly forty administrator selectors, including the responsive query, are now prefixed with the administrator shell class.

Two smaller traps were avoided in the same pass: a hover transform had to restate the vertical centring transform or the reveal button jumped, and entrance animations use fill-mode backwards rather than both - with both, a finished animation keeps winning the cascade and silently disables every hover transform.

Profile picture and banner (NEW)

A collapsible edit section with a two-megabyte picture limit and a three-megabyte background limit, validated client-side before the file is even read. The update writes bytes to disk and stores only the URL, using a targeted update rather than a full document save, which would otherwise read the multi-megabyte field back at roughly ten milliseconds per kilobyte.

A version stamp lets the console re-fetch pictures exactly once, on save, rather than on every poll. Picture reads use a dedicated slow-tolerant database connection with a sixty-second socket timeout and a two-connection pool, de-duplicated so concurrent requests share one read. A failure degrades to "no picture" rather than an error, because a failing multi-megabyte read previously held a pooled socket for the full timeout and took sign-in down with it.

```
server/utils/pictures.js  
server/utils/bigDocuments.js
```

Change password and rotate authenticator key (NEW)

- Changing the administrator password requires the current password and a current authenticator code. A wrong password or code returns a client error rather than an authentication error - the latter used to discard a working token and create an unwinnable loop. A new password equal to the current one is refused.
- Rotating the authenticator key requires a current valid code, generates a new secret, returns a QR code and a manual-entry key, and invalidates the old key immediately. The interface states plainly that the old key stops working immediately, so the new one is scanned before signing out.

4.12 Administrator notification centre

Anchored bell with two kinds of row (NEW)

The panel opens on hover and click, is positioned with a live re-measurement on scroll and resize so it never flashes at a fallback position, and uses a custom property to point its arrow at the bell.

- **Live configuration warnings** are recomputed on every read, never stored, and therefore have no identifier. They are marked non-dismissible and rendered with a fix chip rather than a delete button - a failing security check is not something an administrator can read away, so "mark all as read" deliberately skips them.
- **Audit rows** are the newest thirty, with per-administrator read state resolved server-side.
- Deep links route a severe flag to assessment management, a subscription request to subscription management, a security event to the security tab, and anything else to a dismissal.
- Mark-as-read accepts a bounded array of validated identifiers - raw values must never reach a database query, which was a documented injection vector in this release.

A TRAP RECORDED FOR FUTURE WORK

The audit event type enumeration originally omitted the subscription type, so every subscription audit row failed validation and vanished. This is the canonical example in this codebase of why a fire-and-forget write needs a round-trip test.

```
my-react-app/src/Pages/AdminDashboard.jsx  
server/models/AdminEvent.js  
server/routes/admin.js
```

5. Backend and API

Seventeen route modules, seventeen models and forty-two server utilities, organised behind a three-stage defence: a meter that guards against floods, a parser that enforces body budgets and per-route size caps, and then the handlers themselves.

5.1 Route surface

MODULE	ENDPOINTS	RESPONSIBILITY
admin.js	36	Overview, users, administrators, subscriptions, both review queues, security monitor, configuration posture, AI checks, profile, session status, notifications
auth.js	27	Captcha, registration, member and administrator sign-in, two-step verification, session refresh, saved-login credentials, two-factor enrolment, email codes, password reset, current user, sign-out, password change, sign-out everywhere, profile updates
adminSupportChats.js	7	Queue listing, thread retrieval, reply, resolve, reopen, assign, delete
subscription.js	13	Public plan listing, quotes, purchases, proof-of-payment requests, cancellations, entitlement state, per-feature checks, and the Server-Sent Events stream
security.js	11	Step-up, summary, devices, revocation, events, recovery codes, recovery email
dashboard.js	9	Dashboard state, intake, energy, reset, day records, calendar, weekly adherence, add and remove from plan, current plan
assessment.js	8	Create, priority status, history, current, an administrator's read of a member's records, results, results update, priority override, delete
chat.js	1	The stateless AI assistant, entitlement-gated and per-account rate limited
polish.js	-	Free-text polishing
supplement_detail.js	-	Supplement detail lookup with a shared cache
insights.js	-	Insights, entitlement-gated
notifications.js	5	Inbox listing, mark read, mark all read, delete read, delete
passwordReset.js	4	Rules, request, validate, complete
supportChat.js	-	Member-side support threads
securityRedeem.js	1	Recovery code redemption, registered before authentication because it is reached mid-sign-in
recommend.js	-	AI recommendations with prompt-injection neutralisation
recommend_improvements.js	-	A helper library rather than a router: allergy exclusion, duplicate detection and blood-test interpretation for the clinical fallback path

5.2 Layered rate limiting

LIMITER	WINDOW	LIMIT (PRODUCTION / LOCAL)	APPLIES TO
Request flood guard	-	Coarse per-address, every API path	All of /api
Session limiter	15 min	400 / 1500	Current-user and subscription reads
Authentication limiter (escalating)	15 min	20 / 200	All authentication routes
User limiter	1 min	120 / 600	Assessment, chat, support, dashboard, insights, notifications, security, Web3
Administrator limiter (escalating)	1 min	60 / 300	All administrator routes
Recommendation limiter	10 min	15	AI recommendations
AI limiter	10 min	60 / 300	Polish and supplement detail
API limiter	1 min	120 / 600	General abuse guard
Sensitive limiter	10 min	60	Credential-touching routes
Purchase limiter	1 min	6 / 120	Subscription purchase
Reset limiter	15 min	10 / 40	Password reset links
Chat limiter	1 min	20 / 90 per user	AI assistant

Body limits are a one-megabyte blanket with a ten-megabyte allowance scoped to exactly three base64 routes: the member profile update, the administrator profile update, and a proof-of-payment submission. A global in-flight budget caps the total JSON buffered across all concurrent requests, and oversized bodies are refused from the declared content length ahead of body parsing.

Response headers hardening includes a strict content security policy with a default-deny source set and no framing, compression and cross-origin controls. The database client uses a pool of ten with server-selection and socket timeouts, refuses to boot without a connection string, and never logs credentials.

```
server/index.js
server/utils/floodGuard.js
server/utils/lockout.js
```

5.3 Models and utilities

Seventeen Mongoose models cover administrator accounts, the audit event feed, assessments, recovery codes, chat threads and messages, dashboard metrics, intake records, password reset tokens, the security event log, sessions, subscription and cancellation requests, cached supplement detail, users, member notifications, and the twenty-two Web3 schemas.

Forty-two server utilities were added or extended. The most significant:

UTILITY	PURPOSE
entitlements	The single source of truth for the feature registry. Own-property lookups mean prototype keys fail closed; permanent subscriptions short-circuit expiry; a null end date is treated as normal rather than missing
planCatalogue	The commercial face: prices, currency resolution, team pricing, and plan-card bullets derived from the entitlement gates so a card cannot advertise something the product does not grant
subscriptionState	The two-layer engine - paid plus override plus a frozen restore snapshot - and the action set
lockout	An escalating ladder applied to both an address bucket and account buckets, with thirty-day offence decay
password	argon2id at the OWASP interactive parameters, bcrypt verification with a transparent upgrade, and the detection helpers
passwordRules	The one policy - length bounds, four character classes, and a guessability check
floodGuard	Three layers: a per-address meter over every API path, a global in-flight byte budget, and content-length pre-refusal
sessions / userSession	Server-authoritative sessions, one active session per account, revocation, and a sliding thirty-day idle timeout
securityAudit	The thirty-finding machine-readable record
attack_probes	Behavioural self-tests for cross-site scripting, NoSQL injection, path traversal with no URL normalisation, prototype pollution, brute-force replay and cross-site request forgery
sanitize	Slang-to-clinical mapping, typo normalisation, garbage detection, tag stripping, and key scrubbing that also strips dollar-prefixed and dotted keys
bigDocuments	A second slow-tolerant database connection for multi-megabyte reads
geo	Address normalisation, private-range short-circuiting, a short-timeout cached lookup and a country cache used for currency resolution
email	SMTP delivery, one-time codes, reset links and codes, status emails, and the two administrator credential emails - one of which deliberately carries no secret
aiProviders	Real-request provider probes with placeholder detection and model-availability checks
envFile	Reload from disk reporting variable names only, never overriding operating-system-provided values

5.4 AI pipeline hardening

- The recommendation route neutralises prompt injection by neutralising delimiter-breaking sequences and override phrases, wraps patient-supplied text in a delimited block with an ignore-instructions guard, and sends only age, gender and health context - locked with a live source tripwire that re-scans the file on every security check.

- The chat route labels recommendation JSON as untrusted data, carries a strict off-topic refusal list, uses possibility language rather than diagnosis, and corrects typos in health terms before answering.
- The polish route is authentication-guarded, validates input type before use, caps length and rejects garbage before spending an API call.
- A helper library for allergy exclusion, duplicate detection and blood-test interpretation documents the pattern for applying all three throughout the recommendation logic.

5.5 Operational scripts

SCRIPT	PURPOSE
notify-admins	The recurring credential-change notice, runnable without a database or a running server, with a dry-run mode and distinct exit codes for full success, partial delivery and nothing sent
send-admin-credentials	The one-time secret hand-off. Passwords are passed as arguments rather than packed into a delimiter-joined string, because a real password may contain the delimiters
migrate-pictures-to-disk	A one-off, idempotent migration of inline base64 profile and banner images out of the database and onto disk, with a dry-run mode
restore-lost-account	Post-incident account restoration that preserves the original identifier so already-written image filenames remain valid

[server/scripts/notify-admins.js](#)
[server/scripts/send-admin-credentials.js](#)
[server/scripts/migrate-pictures-to-disk.js](#)
[server/scripts/restore-lost-account.js](#)

6. Security Programme

A thirty-finding audit executed across six phases, with twenty-three remediations shipped in code. This section summarises the programme; the full register lives in the security audit report.

6.1 Audit summary

SEVERITY	FINDINGS	EXAMPLE
Critical	2	Live credentials committed to a public repository; secrets reachable from code, logs, responses and the client bundle
High	8	Query-string tokens accepted on general endpoints; unvalidated identifier arrays reaching a database query; self-administrator disable not blocked
Medium	9	Two prototype-chain lookups granting paid tiers; unbounded identifier searches; oversized base64 routes
Low	7	Missing cache headers on health responses; incomplete projected fields
Informational	4	No CI, containerisation or automated dependency updates; an unmaintained authenticator library

6.2 Notable remediations

- Live credentials were removed from code, logs, responses and the client bundle, and a final sweep was confirmed clean. Historical secret values in public repository history are burned and are deliberately not reproduced anywhere in this document.
- Authenticator replay protection is scoped per account, fixing a defect that prevented more than one administrator from completing verification per window.
- Token query parameters were removed from general endpoints; only the Server-Sent Events route copies a query token into a header, and it does so before authentication rather than after.
- Both entitlement registries now use own-property lookups, so a prototype key such as constructor can no longer grant a paid tier.
- The administrator bearer token is still held in local storage. This is recorded as an accepted risk, mitigated by the strict content security policy, the fifteen-minute token lifetime and the ten-minute idle kill.
- Session validation moved server-authoritative with a short validation cache and returns a service-unavailable response on lookup failure, so a database outage never signs anyone out.
- A banned-account check moved after password verification, removing an authentication-versus-authorisation oracle.

6.3 Adversarial verification

SUITE	COVERAGE	RESULT
Glitch hunt	120 probes across authentication, sessions, entitlements, direct-object reference, injection, prototype chains, parameter bounds, cross-site scripting, open redirect, lockout, mass assignment, administrator boundaries and output hygiene	120 / 120 passed
Web3 glitch hunt	132 probes: nine direct-object-reference attempts, fifteen malformed identifier endpoints, six overflow attempts, twenty non-finite numerics, governance bounds, and race conditions across wallet, check-in, escrow, loyalty, stock, dispute, voting, upvotes, NFTs and bookings	132 / 132 passed
Dependency audit	Both workspaces	0 vulnerabilities

7. Progressive Web App and Mobile

7.1 Installable application (NEW)

The client builds as an installable Progressive Web App with automatic update registration. The service worker activates new versions silently - a confirmation prompt previously left long-lived tabs running a stale build - and re-checks registration every fifteen minutes. In development every worker and cache is unregistered on load so the dev server never serves stale bundles.

API responses are deliberately never cached, which previously produced stale dashboard data. Runtime caching is limited to web fonts. Offline readiness is logged on load.

```
my-react-app/vite.config.js  
my-react-app/src/main.jsx
```

7.2 Manifest, icons and metadata (NEW)

- Application name, short name, standalone display, green theme colour, portrait-primary orientation, and health / lifestyle / wellness categories.
- **Two long-press app shortcuts** - Dashboard, described as viewing your daily supplement plan, and New Assessment.
- Icons at 192 and 512 pixels, each shipped as both a standard and a maskable icon, plus an Apple touch icon, a scalable favicon and a robots file.
- Light and dark theme colours, Apple web-app capability and status-bar styling, and a strict content security policy meta tag in the document head.

```
my-react-app/public/manifest.json  
my-react-app/index.html
```

7.3 Custom install banner (NEW - currently not mounted)

A branded install card with an install control and a dismiss action, which waits three seconds after the browser fires its install prompt, suppresses the browser's own mini-infobar, detects an already-installed display mode, and remembers a dismissal for seven days.

KNOWN GAP

This component is complete but is not currently mounted in the router or the entry point, so the banner will not appear in the running application. It is listed in section 9 as an outstanding item rather than being described here as a shipped feature.

7.4 Android packaging (NEW)

The application is wrapped for Android with Capacitor, using a distinct application identifier, the SuppliWise display name and the built client directory as its web root. Cleartext traffic and an HTTP scheme are enabled so

a device on the same network can reach a local backend, and build instructions for sideloading a debug APK ship with the repository.

```
my-react-app/capacitor.config.json  
my-react-app/android/  
BUILD_APK_INSTRUCTIONS.md
```

8. Testing and Verification

SUITE	COMMAND	SCOPE	RESULT
Server unit tests	npm test (server)	44 test files	68 / 68
Client unit tests	npm test (client)	9 test files	9 / 9
Web3 end-to-end flows	test-web3-flows.js	All twenty blockchain features over real HTTP	81 / 81
Session flows	test-session-flows.js	Issue, validate, switch, revoke, expire	51 / 51
Subscription flows	npm run test:flows	Server-sent events, tier gates, expiry	29 / 29
Glitch hunt	glitch-hunt.js	120 adversarial probes	120 / 120
Web3 glitch hunt	glitch-hunt-web3.js	132 adversarial probes	132 / 132
Client lint	npx eslint src	Whole client source	0 errors
Production build	npx vite build	Client bundle and service worker	Success
Dependency audit	npm audit	Both workspaces	0 vulnerabilities

8.1 Tests worth calling out

- A client test imports the **real server entitlement module** and asserts the two feature registries are identical, so a one-sided edit fails the build.
- The membership quantity stepper is pinned by a test, guaranteeing the stepper and the buy button can never disagree.
- The client password checklist is asserted rule-by-rule against the server policy.
- A test database guard refuses to run destructive tests against the application database - it exists because an earlier harness version dropped the live data.
- The administrator credential hand-off tests assert that a password rewrite touches only the named entry, leaves neighbours byte-identical, and that a rebuild after a change restores the chosen password.
- The priority override suite covers concurrency, prototype pollution, direct-object reference and expiry restoration.
- The projection test asserts that the lean administrator user list supplies every field the subscription-liveness calculation reads.

9. Known Gaps and Manual Actions

Recorded here so the release note matches the system.

9.1 Manual actions required before public deployment

1. Rotate the token signing secret.
2. Rotate all six administrator passwords.
3. Rotate all six authenticator seeds.
4. Rotate the mail application password.
5. Purge repository history and decide whether the repository remains public.
6. Set the trust-proxy flag behind a reverse proxy; otherwise the client address is spoofable.
7. Serve the frame-ancestors directive as an HTTP header - a document meta tag cannot carry it.
8. Add continuous integration so these suites run on every push.
9. Re-run the audit after the remediations land.
10. Complete the manual visual pass listed in section 9.3.

9.2 Accepted risks, documented and not changed

- The administrator bearer token is stored in local storage, mitigated by the content security policy, the fifteen-minute token lifetime and the ten-minute idle kill.
- The content security policy still allows inline scripts and has never been observed enforcing in a browser.
- The authenticator library is unmaintained.
- User tokens carry no expiry claim; a sliding thirty-day server-side idle timeout governs instead.
- Rate limiting, lockout state and the subscription bus are in-process, which makes the current design single-instance.
- The supplement detail cache and the ten-megabyte JSON body limit were reviewed and accepted.
- There is no continuous integration, containerisation or automated dependency update pipeline.

9.3 Items still requiring a manual visual pass

The desktop browser was unavailable for part of this release. The following were built, lint-clean, unit-tested and included in a successful production build, but have not been observed in a running browser:

- Cross-tab entitlement relay and instant re-render on an administrator plan change.
- Content security policy enforcement against the development hot-reload client.
- Notification hover, scroll and arrow anchoring behaviour in both consoles.
- The audit record widget and the security report download.
- The chat panel fixes, including the jump-to-newest anchoring.
- The administrator profile redesign and its class-name scoping fix.

- The custom install banner, which additionally is not currently mounted.

10. Appendix - Feature to Source Map

A quick index from this document back to the code that implements it.

FEATURE AREA	PRIMARY IMPLEMENTATION FILES
Application shell and routing	my-react-app/src/App.jsx, main.jsx, index.html, vite.config.js
API client and session handling	my-react-app/src/api.js, src/auth/authState.js, src/hooks/useAuth.js
Landing and public pages	my-react-app/src/Pages/HomePage.jsx, VerifyPage.jsx, SharePage.jsx
Authentication	my-react-app/src/Pages/SignIn.jsx, LogIn.jsx, ForgotPassword.jsx, ResetPassword.jsx
Assessment	my-react-app/src/Pages/AssessmentPage.jsx, server/routes/assessment.js, server/utls/severity.js, priorityRules.js, priorityGate.js
Results and plan	my-react-app/src/Pages/ResultsPage.jsx, src/utls/exportPDF.js, src/utls/wellnessReport.js, src/utls/safeUrl.js
Recommendations library	my-react-app/src/Pages/RecommendationsPage.jsx
Dashboard and tracking	my-react-app/src/Pages/DashboardPage.jsx, TrackIntakePage.jsx, server/routes/dashboard.js
Insights	my-react-app/src/Pages/InsightsPage.jsx, server/routes/insights.js
History	my-react-app/src/Pages/HistoryPage.jsx
Profile	my-react-app/src/Pages/ProfilePage.jsx, src/Components/ProfileAvatar/, src/utls/pictureUrl.js
Account security	my-react-app/src/Components/ProfileSecurityControls/, server/routes/security.js, securityRedeem.js, server/models/BackupCode.js, SecurityEvent.js
Plans and checkout	my-react-app/src/Pages/PricingPage.jsx, src/subscription/, src/Components/MyPlanRequests/, src/Components/UpgradeModal/, src/Components/PlanLockedCard/
Subscription engine	server/utls/entitlements.js, planCatalogue.js, subscriptionState.js, subscriptionBus.js, subscriptionRequests.js, subscriptionCancels.js, currency.js, paymentInstructions.js
Notifications and support	my-react-app/src/Components/UserNotifications/, SupportInbox/, src/Pages/SupportChatPage.jsx, server/routes/notifications.js, supportChat.js, adminSupportChats.js
AI chat assistant	my-react-app/src/Pages/ChatAssistant.jsx, server/routes/chat.js, server/utls/chatSafety.js
Web3 layer	server/blockchain/ (crypto, ledger, engine, rules, seed), server/models/Web3.js, server/routes/web3/, my-react-app/src/Components/Web3Panels/
Web3 pages	my-react-app/src/Pages/Web3HubPage.jsx, MarketplacePage.jsx, GovernancePage.jsx, src/api/web3.js, src/Components/Web3PlanGate/
Administrator console	my-react-app/src/Pages/AdminDashboard.jsx, AdminLogin.jsx, AdminChangePassword.jsx, src/Components/AdminTopbar/, AdminProtectedRoute.jsx

FEATURE AREA	PRIMARY IMPLEMENTATION FILES
Administrator features	my-react-app/src/Components/AdminSubscriptionPanel/, AdminSubscriptionRequests/, AdminSubscriptionCancels/, AdminSupportChats/, SecurityStatus/
AI control	server/utls/aiProviders.js, envFile.js, server/routes/admin.js
Security programme	server/utls/securityAudit.js, attack_probes.js, lockout.js, floodGuard.js, password.js, passwordRules.js, totp.js, my-react-app/src/utls/securityReport.js
Mobile and PWA	my-react-app/public/manifest.json, vite.config.js, capacitor.config.json, android/, src/Components/PWAInstallPrompt.jsx
Operational scripts	server/scripts/ (notify-admins, send-admin-credentials, migrate-pictures-to-disk, restore-lost-account)
Test harnesses	server/Test File/ (44 files, 6 harnesses), my-react-app/src/**/*.test.js (9 files)
Manuals	docs/USER_MANUAL.md, docs/USER_GUIDE.md, docs/DEVELOPER_MANUAL.md, docs/DEVELOPER_GUIDE.md

DOCUMENT CONTROL

SW-PN-2026-09-29 - Rev. 1.0 - 29 September 2026. Prepared from build e725eb4 against Baseline commit 6daf284 (Adjustments in Session Expiry). Regenerate from docs/generate_patch_notes.py when the implementation changes.